ZAP by Checkmarx Scanning Report

Sites: https://firefox-settings-attachments.cdn.mozilla.net http://oimg.nbcuni.com http://10.10.13.11

Generated on Sun, 11 Oct 2026 13:47:04

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	3
Informational	4

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	4
Low	Warning		ZAP warnings logged - see the zap.log file for details	45
Info	Informational		Percentage of network failures	8 %
Info	Informational	http://10.10.13.11	Percentage of responses with status code 2xx	47 %
Info	Informational	http://10.10.13.11	Percentage of responses with status code 3xx	30 %
Info	Informational	http://10.10.13.11	Percentage of responses with status code 4xx	20 %

Info	Informational	http://10.10.13.11	Percentage of responses with status code 5xx	1 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type application/javascript	21 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type application/xml	7 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type audio/ogg	28 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type image/png	7 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type image/vnd.microsoft.icon	7 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type text/css	7 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content type text/html	14 %
Info	Informational	http://10.10.13.11	Percentage of endpoints with content	7 %

			type text /plain	
Info	Informational	http://10.10.13.11	Percentage of endpoints with method GET	100 %
Info	Informational	http://10.10.13.11	Count of total endpoints	14
Info	Informational	http://10.10.13.11	Percentage of slow responses	2 %
Info	Informational	http://oimg.nbcuni.com	Percentage of responses with status code 2xx	100 %
Info	Informational	http://oimg.nbcuni.com	Percentage of endpoints with content type text /plain	100 %
Info	Informational	http://oimg.nbcuni.com	Percentage of endpoints with method GET	100 %
Info	Informational	http://oimg.nbcuni.com	Count of total endpoints	1
Info	Informational	http://oimg.nbcuni.com	Percentage of slow responses	100 %
Info	Informational	https://10.10.13.11	Percentage of responses with status code 2xx	100 %
Info	Informational	https://10.10.13.11	Percentage of slow responses	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with content type image /png	100 %
		https://firefox-settings-	Percentage of endpoints	

Info	Informational	attachments.cdn.mozilla.net	with method GET	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Count of total endpoints	1

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	2
Vulnerable JS Library	Medium	2
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	1
Strict-Transport-Security Header Not Set	Low	1
X-Content-Type-Options Header Missing	Low	Systemic
Information Disclosure - Suspicious Comments	Informational	3
Retrieved from Cache	Informational	1
Session Management Response Identified	Informational	1
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://10.10.13.11
Node Name	http://10.10.13.11
Method	GET
Attack	
Evidence	
Other Info	
URL	http://10.10.13.11/
Node Name	http://10.10.13.11/
Method	GET
Attack	
Evidence	
Other	

Info	
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**Vulnerable JS Library**
Description	The identified library appears to be vulnerable.
URL	http://10.10.13.11/js/main-acba06a5.js.pagespeed.jm.YdSb2z1rih.js
Node Name	http://10.10.13.11/js/main-acba06a5.js.pagespeed.jm.YdSb2z1rih.js
Method	GET
Attack	
Evidence	="2.1.4",Z=function(t,e){return new Z.fn.init(t,e)},tt=/^[\s\uFEFF\xA0]+|[\s\uFEFF\xA0]+$/g, et=/^-ms-/,nt=/-([\da-z])/gi,rt=function(t,e){return e.toUpperCase()};Z.fn=Z.prototype={jquery:
Other Info	The identified library jquery, version 2.1.4 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2015-9251 CVE-2019-11358 https://github.com/jquery/jquery/issues/2432 http://research.insecurelabs.org/jquery/test/ http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/advisories/GHSA-rmxg-73gg-4p98 https://nvd.nist.gov/vuln/detail/CVE-2015-9251 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://bugs.jquery.com/ticket/11974 https://github.com/jquery/jquery.com/issues/162 https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
URL	http://10.10.13.11/js/vendor/vendor-48ca455c.js.pagespeed.jm.V7Qfw6bd5C.js
Node Name	http://10.10.13.11/js/vendor/vendor-48ca455c.js.pagespeed.jm.V7Qfw6bd5C.js
Method	GET
Attack	
Evidence	="2.1.3",Z=function(e,t){return new Z.fn.init(e,t)},ee=/^[\s\uFEFF\xA0]+|[\s\uFEFF\xA0]+$/g, te=/^-ms-/,ne=/-([\da-z])/gi,ie=function(e,t){return t.toUpperCase()};Z.fn=Z.prototype={jquery:
Other Info	The identified library jquery, version 2.1.3 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2015-9251 CVE-2019-11358 https://github.com/jquery/jquery/issues/2432 http://research.insecurelabs.org/jquery/test/ http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/advisories/GHSA-rmxg-73gg-4p98 https://nvd.nist.gov/vuln/detail/CVE-2015-9251 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://bugs.jquery.com/ticket/11974 https://github.com/jquery/jquery.com/issues/162 https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Instances	2
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395

WASC Id	
Plugin Id	10003

Low	**Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://10.10.13.11/favicon.ico
Node Name	http://10.10.13.11/favicon.ico
Method	GET
Attack	
Evidence	X-Powered-By: PHP/5.5.29
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	**Strict-Transport-Security Header Not Set**
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/quicksuggest-amp/20260912180131--icon-bb5f4c722043fdae3767ac4f4fb388d1b4395cacf170ca8779ebd1fdebdc2337--484ad920-5197-4377-b856-a9507035cb2b.png
Node Name	https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/quicksuggest-amp/20260912180131--icon-bb5f4c722043fdae3767ac4f4fb388d1b4395cacf170ca8779ebd1fdebdc2337--484ad920-5197-4377-b856-a9507035cb2b.png
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security_Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security

	https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://10.10.13.11
Node Name	http://10.10.13.11
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://10.10.13.11/css/A.main-600a9791.css.pagespeed.cf.ajSCfyGfQ4.css
Node Name	http://10.10.13.11/css/A.main-600a9791.css.pagespeed.cf.ajSCfyGfQ4.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://10.10.13.11/images/btn-play.png.pagespeed.ce.FeqZbWWoGS.png
Node Name	http://10.10.13.11/images/btn-play.png.pagespeed.ce.FeqZbWWoGS.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://10.10.13.11/js/s_code.js.pagespeed.jm.I78cfHQpbQ.js
Node Name	http://10.10.13.11/js/s_code.js.pagespeed.jm.I78cfHQpbQ.js
Method	GET
Attack	
Evidence	
	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still

Other Info	affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://10.10.13.11/robots.txt
Node Name	http://10.10.13.11/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/quicksuggest-amp/20260912180131--icon-bb5f4c722043fdae3767ac4f4fb388d1b4395cacf170ca8779ebd1fdebdc2337--484ad920-5197-4377-b856-a9507035cb2b.png
Node Name	https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/quicksuggest-amp/20260912180131--icon-bb5f4c722043fdae3767ac4f4fb388d1b4395cacf170ca8779ebd1fdebdc2337--484ad920-5197-4377-b856-a9507035cb2b.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	**Information Disclosure - Suspicious Comments**
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://10.10.13.11/js/main-acba06a5.js.pagespeed.jm.YdSb2z1rih.js
Node Name	http://10.10.13.11/js/main-acba06a5.js.pagespeed.jm.YdSb2z1rih.js
Method	GET
Attack	
Evidence	select
Other	The following pattern was used: \bSELECT\b and was detected in likely comment: "//"),f.type=e.method||e.type||f.method||f.type,f.dataTypes=Z.trim(f.dataType||"*").toLowerCase().

Info	match(ht)||[""],null==f.crossDo", see evidence field for the suspicious comment/snippet.
URL	http://10.10.13.11/js/s_code.js.pagespeed.jm.I78cfHQpbQ.js
Node Name	http://10.10.13.11/js/s_code.js.pagespeed.jm.I78cfHQpbQ.js
Method	GET
Attack	
Evidence	Debug
Other Info	The following pattern was used: \bDEBUG\b and was detected in likely comment: "//'+t1+'/b /ss/'+s.un+'/'+(s.mobi"+"le?'5.1':'1')+'/'+s.version+(s.tcn?'T':")+(s.tagContainerMarker?\"-\"+s. tagContainerMarker:\", see evidence field for the suspicious comment/snippet.
URL	http://10.10.13.11/js/vendor/vendor-48ca455c.js.pagespeed.jm.V7Qfw6bd5C.js
Node Name	http://10.10.13.11/js/vendor/vendor-48ca455c.js.pagespeed.jm.V7Qfw6bd5C.js
Method	GET
Attack	
Evidence	username
Other Info	The following pattern was used: \bUSERNAME\b and was detected in likely comment: " //www.w3.org/2000/svg"},j={},A={},P={},L=[],N=L.slice,D=function(e,n,i,r){var s,o,a,l,c=t. createElement("div"),u=t.body,d=u||t.c", see evidence field for the suspicious comment /snippet.
Instances	3
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	**Retrieved from Cache**
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/quicksuggest-amp /20260912180131--icon-bb5f4c722043fdae3767ac4f4fb388d1b4395cacf170ca8779ebd1fdebdc2337--484ad920-5197-4377-b856-a9507035cb2b.png
Node Name	https://firefox-settings-attachments.cdn.mozilla.net/main-workspace/quicksuggest-amp /20260912180131--icon-bb5f4c722043fdae3767ac4f4fb388d1b4395cacf170ca8779ebd1fdebdc2337--484ad920-5197-4377-b856-a9507035cb2b.png
Method	GET
Attack	
Evidence	HIT
Other Info	
Instances	1

Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	**Session Management Response Identified**
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://oimg.nbcuni.com/b/ss/nbcuglobal,nbcuusanetworkd/1/H.27.5/s19442029903866?AQB=1&ndh=1&t=11%2F9%2F2026%2016%3A13%3A33%200%200&fid=24627313424F1FEE-00187CCA6CE351A6&ce=UTF-8&ns=nbcuniversal&pageName=Mr.%20Robot%20%3A%20Who%20Is%20Mr.%20Robot%20%3A%20Email%20Sign-Up%20%3A%20Loading%20Sequence&g=http%3A%2F%2F10.10.13.11%2F&cc=USD&server=10.10.13.11&events=event6&c2=Drama&c3=Features&c4=Mr.%20Robot%20%3A%20Who%20Is%20Mr.%20Robot&v4=D%3Dc4&c5=Mr.%20Robot%20%3A%20Who%20Is%20Mr.%20Robot%20%3A%20Email%20Sign-Up&c6=http%3A%2F%2F10.10.13.11%2F&c8=Cable&v8=Cable&c9=USA%20Network&v9=Mr.%20Robot%20%3A%20Who%20Is%20Mr.%20Robot%20%3A%20Email%20Sign-Up%20%3A%20Loading%20Sequence&c10=Mr.%20Robot&v10=D%3Dc10&c11=Mr.%20Robot%20%7C%20Mr.%20Robot%20%3A%20Who%20Is%20Mr.%20Robot%20%3A%20Email%20Sign-Up%20%3A%20Loading%20Sequence&c12=USA%20Network%20%7C%20Mr.%20Robot&c13=New&c32=New%20Site&v32=Features&v43=http%3A%2F%2F10.10.13.11%2F&v45=USA%20Network&c60=Not%20Sponsored&c68=D%3Dv68&v68=Desktop&c69=D%3Dv69&v69=600&c70=D%3Dv70&v70=1200&c71=D%3Dv71&v71=Desktop&h1=Cable%7CUSA%20Network%7CMr.%20Robot&h2=Drama%7CMr.%20Robot%7CFeatures%7CMr.%20Robot%20%3A%20Who%20Is%20Mr.%20Robot&h3=10.10.13.11&s=1200x600&c=24&j=1.6&v=N&k=Y&bw=1200&bh=600&p=PDF%20Viewer%3BChrome%20PDF%20Viewer%3BChromium%20PDF%20Viewer%3BMicrosoft%20Edge%20PDF%20Viewer%3BWebKit%20built-in%20PDF%3B&AQE=1
Node Name	http://oimg.nbcuni.com/b/ss/nbcuglobal,nbcuusanetworkd/1/H.27.5/s19442029903866 (AQB,AQE,bh,bw,c,c10,c11,c12,c13,c2,c3,c32,c4,c5,c6,c60,c68,c69,c70,c71,c8,c9,cc,ce,events,fid,g,h1,h2,h3,j,k,ndh,ns,p,pageName,s,server,t,v,v10,v32,v4,v43,v45,v68,v69,v70,v71,v8,v9)
Method	GET
Attack	
Evidence	fid
Other Info	url:fid
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.

Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	**User Agent Fuzzer**
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://10.10.13.11
Node Name	http://10.10.13.11
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://10.10.13.11/
Node Name	http://10.10.13.11/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://10.10.13.11/audio
Node Name	http://10.10.13.11/audio
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://10.10.13.11/audio
Node Name	http://10.10.13.11/audio
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://10.10.13.11/audio
Node Name	http://10.10.13.11/audio
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104